# Studieguide

## Säker nätverksteknik

Uttömmande sammanfattning av kursinnehåll

Nätverkstekniker – 30 poäng

Lärare: Johan Öhman Saldes

VT 2026 – Göteborg

**Om denna guide**
Denna studieguide är en uttömmande genomgång av allt kursinnehåll som behandlats från kursstart den 12 januari till och med den 16 februari 2026. Varje föreläsningsdags innehåll behandlas i detalj. Guiden är utformad som ditt primära studieunderlag inför tentamen den 20 februari 2026.

**Föreläsningar:**

- 12 jan: Grundläggande säkerhetskoncept, CIA-triaden, hotmodeller, riskanalys
- 13 jan: Nätverkssäkerhetsarkitektur, Defense in Depth, segmentering, protokoll
- 19 jan: Brandväggstyper, ACL, NGFW, UTM
- 20 jan: Praktisk brandväggskonfiguration, NAT/PAT, regeldesign
- 26 jan: IDS/IPS, detektionsmetoder, false positives/negatives
- 27 jan: Logganalys, SIEM, incidentdetektion
- 2 feb: SASE – komponenter, cloud-delivered security
- 3 feb + 10 feb: Zero Trust, ZTNA, IAM, SWG, CASB
- 9 feb + 16 feb: Penetrationstestning, Nmap, Nessus, OpenVAS
- 17 feb: Nätverksattacker och försvar (förhandsmaterial)

# Contents

**1 Grundläggande säkerhetskoncept** **3**
1.1 Introduktion till nätverkssäkerhet . . . 3
1.2 CIA-triaden . . . 3
1.3 Hotmodeller och riskanalys . . . 4
1.3.1 Grundläggande begrepp . . . 5
1.3.2 Riskanalysprocessen . . . 5

**2 Nätverkssäkerhetsarkitektur** **6**
2.1 Defense in Depth (Djupförsvar) . . . 6
2.2 Nätverkszoner och segmentering . . . 6
2.2.1 DMZ – Demilitarized Zone . . . 6
2.2.2 Trust Zones och VLAN . . . 7
2.2.3 Micro-segmentering . . . 7
2.3 Säkerhetsprotokoll . . . 7
2.3.1 TLS/SSL . . . 7
2.3.2 IPsec . . . 7
2.3.3 SSH (Secure Shell) . . . 8

**3 Brandväggar** **9**
3.1 Packet Filter Firewall (Paketfilter) . . . 9
3.2 Stateful Firewall . . . 9
3.3 Application Layer Firewall (Proxy-brandvägg) . . . 9
3.4 NGFW – Next-Generation Firewall . . . 10
3.5 UTM – Unified Threat Management . . . 10
3.6 Access Control Lists (ACL) . . . 10
3.7 NAT och PAT . . . 11
3.8 Brandväggspolicyer och regeldesign . . . 11

**4 Intrusion Detection & Prevention Systems** **12**
4.1 IDS – Intrusion Detection System . . . 12
4.2 IPS – Intrusion Prevention System . . . 12
4.3 Detektionsmetoder . . . 12
4.3.1 Signaturbaserad detektion . . . 13
4.3.2 Beteendebaserad (anomali-baserad) detektion . . . 13
4.4 False Positives och False Negatives . . . 13
4.5 IDS/IPS-konfiguration och tuning . . . 13

**5 Logganalys och SIEM** **14**
5.1 Loggkällor i ett nätverk . . . 14
5.2 Centraliserad logghantering . . . 14
5.3 SIEM – Security Information and Event Management . . . 14
5.4 Indikatorer på säkerhetsincidenter (IoC) . . . 15

**6 SASE – Secure Access Service Edge** **16**
6.1 Varför behövs SASE? . . . 16
6.2 SASE – definition . . . 16
6.3 Traditionell säkerhet vs SASE . . . 18

**7 Zero Trust** **19**
7.1 Paradigmskiftet . . . 19

7.2 Tre grundprinciper . . . 19
7.3 ZTNA vs VPN . . . 19
7.4 IAM – Identity and Access Management . . . 19
7.4.1 Autentisering . . . 19
7.4.2 SSO (Single Sign-On) . . . 20
7.4.3 RBAC . . . 20
7.4.4 Identity Providers (IdP) . . . 20

**8 Penetrationstestning och sårbarhetsscanning 21**
8.1 Etisk hacking . . . 21
8.2 Typer av penetrationstest . . . 21
8.3 Faserna i ett penetrationstest . . . 22
8.4 Verktyg . . . 22
8.4.1 Nmap (Network Mapper) . . . 22
8.4.2 Nessus . . . 22
8.4.3 OpenVAS . . . 22
8.5 Sårbarhetsbedömning vs penetrationstest . . . 23

**9 Nätverksattacker och försvar 24**
9.1 DDoS – Distributed Denial of Service . . . 24
9.2 Man-in-the-Middle (MitM) . . . 24
9.3 ARP Poisoning (ARP Spoofing) . . . 25
9.4 DNS Spoofing (DNS Cache Poisoning) . . . 25
9.5 Social Engineering och Phishing . . . 26

**10 Ordlista: engelska termer 27**

**11 Studietips och tentamensförberedelse 29**
11.1 Tentamen . . . 29
11.2 Studiestrategier . . . 29
11.3 Kontrollfrågor att öva på . . . 29

# Grundläggande säkerhetskoncept

*Föreläsning: 12 januari 2026, 13:00–16:00*

## Introduktion till nätverkssäkerhet

Nätverkssäkerhet handlar om att skydda nätverksinfrastruktur, data i transit och nätverksanslutna resurser mot obehörig åtkomst, missbruk, modifiering och avbrott. Det omfattar en kombination av hårdvara, mjukvara, policyer och processer.

Nätverkssäkerhet är inte ett tillstånd utan en *process*. Hot förändras ständigt, nya sårbarheter upptäcks och IT-miljöer utvecklas. Säkerhetsarbetet måste vara kontinuerligt och iterativt.

**Centrala frågor:**

- Vem har åtkomst till nätverket och dess resurser?
- Vilken typ av trafik tillåts passera?
- Hur skyddas data under överföring och i vila?
- Hur upptäcker vi obehörig aktivitet?
- Hur reagerar vi på säkerhetsincidenter?

## CIA-triaden

CIA-triaden är den mest fundamentala modellen inom informationssäkerhet. Alla säkerhetsåtgärder kan mappas till en eller flera av dessa tre principer.

**Confidentiality – Konfidentialitet**

Information och resurser ska bara vara tillgängliga för behöriga personer och system.
**Skyddsmekanismer:**

- **Kryptering:** Omvandlar data till oläsbart format. *Symmetrisk kryptering* använder samma nyckel för kryptering och dekryptering (t.ex. AES-256) – snabbt, används för datavolymer. *Asymmetrisk kryptering* använder ett nyckelpar med publik och privat nyckel (t.ex. RSA) – långsammare, används för nyckelutbyte och signaturer. Kryptering tillämpas på data i vila (diskkryptering, databaskryptering) och data i transit (TLS, IPsec, SSH).
- **Åtkomstkontroll:** Autentisering (verifiera identitet – lösenord, certifikat, biometri, MFA) och auktorisering (vad den identifierade personen får göra – RBAC, ACL). Principen om *minsta möjliga behörighet* (Least Privilege) innebär att varje användare bara ska ha den åtkomst som krävs.
- **Dataklassificering:** Klassificera information efter känslighet (offentlig, intern, konfidentiell, hemlig). Olika nivåer kräver olika skydd.
- **Nätverkssegmentering:** Isolera känsliga system i egna segment. En kompromettерad webbserver i DMZ ska inte ha direkt åtkomst till databasservern.

*Hot:* Avlyssning (eavesdropping/sniffing), MitM-attacker, dataläckor, stöld av inloggningsuppgifter, social engineering.

**Integrity – Integritet**

Information ska vara korrekt, fullständig och opåverkad av obehöriga ändringar. Både avsiktliga manipulationer och oavsiktliga fel hotar integriteten.

**Skyddsmekanismer:**

- **Hashfunktioner:** Genererar ett unikt "fingeravtryck" av data. Om en enda bit ändras, ändras hela hashen. Algoritmer: SHA-256, SHA-3. MD5 och SHA-1 anses osäkra (kollisionsattacker). Hashfunktioner är envägsfunktioner – det ska vara beräkningsmässigt omöjligt att härleda originaldatan.
- **Digitala signaturer:** Kombinerar hashning med asymmetrisk kryptering. Avsändaren hashar meddelandet och krypterar hashen med sin privata nyckel. Mottagaren dekrypterar med avsändarens publika nyckel och jämför. Verifierar både integritet och autenticitet (icke-förnekande).
- **Versionskontroll:** Spåra alla ändringar av data och konfigurationer. Återställning till känt tillstånd.
- **Filintegritetskontroll:** Verktyg som Tripwire/OSSEC övervakar systemfiler och larmar vid oväntade ändringar.
- **Checksummor:** Verifierar att data inte korrumperats under överföring.

*Hot:* MitM-attacker, malware, SQL injection, obehörig databasmanipulering, ARP poisoning, DNS spoofing.

**Availability – Tillgänglighet**

System, nätverk och data ska vara åtkomliga och funktionella för behöriga användare när de behövs.

**Skyddsmekanismer:**

- **Redundans:** Duplicera kritiska komponenter – servrar (kluster), nätverkslänkar (dual-homing), strömförsörjning (UPS, generatorer), lagring (RAID, replikering).
- **Lastbalansering:** Fördela trafik över flera servrar. L4 (TCP/UDP) eller L7 (HTTP).
- **Backup och disaster recovery:** Regelbundna backuper, testa återställning. RTO (Recovery Time Objective) och RPO (Recovery Point Objective). 3-2-1-regeln: 3 kopior, 2 medier, 1 offsite.
- **DDoS-skydd:** Molnbaserade tjänster (Cloudflare, AWS Shield) som absorberar attacktrafik. Rate limiting och trafikfiltrering.
- **Patchhantering:** Hålla system uppdaterade förebygger sårbarheter.
- **Kapacitetsplanering:** Dimensionera infrastruktur för förväntad och oväntad belastning.

*Hot:* DDoS-attacker, hårdvarufel, strömavbrott, naturkatastrofer, ransomware, konfigurationsfel.

De tre pelarna står ibland i konflikt:

- Hög **konfidentialitet** (kryptering + MFA + strikt åtkomst) kan minska **tillgängligheten**.
- Hög **tillgänglighet** (många åtkomstpunkter, enkel inloggning) kan riskera **konfidentialiteten**.
- Strikta **integritetskontroller** (verifiering vid varje transaktion) kan påverka **tillgängligheten**.

Säkerhetsarbete handlar om att hitta rätt balans utifrån organisationens behov och risktolerans.

## Hotmodeller och riskanalys

## Grundläggande begrepp

**Tillgång (Asset)**
Allt som har värde – servrar, data, nätverksinfrastruktur, tjänster, personal, rykte.

**Hot (Threat)**
Potentiell händelse som kan skada en tillgång. Kan vara angripare, naturkatastrof, systemfel, mänskligt misstag.

**Hotaktör (Threat Actor)**
Den som utför hotet. Kategorier: statsstödda aktörer, cyberkriminella, hacktivister, insiders, opportunistiska angripare.

**Sårbarhet (Vulnerability)**
Svaghet som kan utnyttjas. Opatchad mjukvara, svaga lösenord, felkonfigurationer.

**Risk**
Sannolikheten att ett hot utnyttjar en sårbarhet × konsekvenserna.

**Exploatering (Exploit)**
Den specifika metoden/koden som utnyttjar en sårbarhet.

**Attackyta (Attack Surface)**
Summan av alla punkter där en angripare kan interagera med systemet.

## Riskanalysprocessen

1. **Identifiera tillgångar och deras värde** – Kartlägg hårdvara, mjukvara, data, tjänster. Bedöm affärspåverkan om tillgången kompromettetras. Klassificera data. Identifiera beroenden.
2. **Identifiera hot** – Externa (hackare, statsstödda, malware, DDoS, phishing), interna (missnöjda anställda, oavsiktliga fel), miljö (brand, översvämning, strömavbrott), supply chain (kompromettetade leverantörer).
3. **Identifiera sårbarheter** – Tekniska (opatchade system, öppna portar, föråldrade protokoll), administrativa (bristande policyer, avsaknad av utbildning), fysiska (oskyddat serverrum). Metoder: sårbarhetsscanning, pentesting, kodgranskning.
4. **Bedöm sannolikhet och konsekvens** – *Kvalitativ:* Skala (låg/medel/hög), riskmatris. *Kvantitativ:* SLE = tillgångsvärde × exponeringsfaktor; ALE = SLE × ARO (Annualized Rate of Occurrence).
5. **Prioritera och välj hanteringsstrategi**
   - **Mitigera:** Implementera säkerhetsåtgärder (vanligast).
   - **Acceptera:** Medvetet godta risken (dokumentera formellt).
   - **Överföra:** Flytta risken (cyberförsäkring, outsourcing).
   - **Undvika:** Sluta med aktiviteten som skapar risken.

Riskanalys handlar *inte* om att eliminera alla risker. Målet är att hantera risker till en **acceptabel nivå**. Restrisken (risk som kvarstår efter åtgärder) ska vara känd och dokumenterad.

# Nätverkssäkerhetsarkitektur

*Föreläsning: 13 januari 2026, 09:00–16:00*

## Defense in Depth (Djupförsvar)

Defense in Depth innebär att man implementerar flera oberoende säkerhetslager så att om ett lager brister, finns nästa som skydd. En angripare måste ta sig förbi alla lager för att nå målet.

**Säkerhetslager i Defense in Depth**

1. **Fysiskt lager**
   Lås, passerkort, biometri, kameror, klimatanläggning, brandskydd. Om angriparen har fysisk åtkomst kan ofta alla digitala skydd kringgås.
2. **Perimeterlager**
   Brandväggar vid nätverksgränser, DMZ, IDS/IPS vid ingress/egress, VPN-gateways, DDoS-mitigering. Första försvarslinjen mot extern trafik.
3. **Nätverkslager (internt)**
   Segmentering med VLAN och interna brandväggar, micro-segmentering, NAC (Network Access Control), 802.1X-autentisering. Begränsar lateral movement.
4. **Värdlager (endpoint)**
   Antivirus/EDR, värdbaserade brandväggar, patchhantering, härdning (stänga onödiga tjänster, ändra standardlösenord), diskkryptering (BitLocker, LUKS).
5. **Applikationslager**
   Autentisering/auktorisering, input-validering, WAF (Web Application Firewall), kodgranskning, SAST/DAST-testning. Applikationer är ofta den direkta attackytan.
6. **Datalager**
   Kryptering i vila och transit, åtkomstkontroll till databaser, DLP (Data Loss Prevention), backup (3-2-1-regeln: 3 kopior, 2 medier, 1 offsite). Data är ofta angriparens slutmål.

**Principen i praktiken:** En angripare som vill nå kunddata måste ta sig förbi: perimeterens brandvägg → nätverkssegmentering → värdskydd på servern → applikationens autentisering → datakryptering. Varje lager lägger till tid, komplexitet och chans till detektion.

## Nätverkszoner och segmentering

### DMZ – Demilitarized Zone

En DMZ är ett isolerat segment mellan det externa (opålitliga) och det interna (betrodda) nätverket. Publikt exponerade tjänster placeras här.

**Arkitekturvarianter:**

- **Single-firewall DMZ:** En brandvägg med tre gränssnitt (internet, DMZ, internt). Enklare men brandväggen blir single point of failure.
- **Dual-firewall DMZ:** Två separata brandväggar – en yttre (internet ↔ DMZ) och en inre (DMZ ↔ internt). Idealt från olika tillverkare. Mer robust och rekommenderad.

**Tjänster i DMZ (typiskt):** Webbservrar, e-postgateways, extern DNS, omvända proxyer, VPN-terminering.

**Trafikflöden:**

- Internet → DMZ: Tillåts (specifika tjänster/portar).
- DMZ → Internt: Mycket begränsat (t.ex. webbserver till databas via specifik port).
- Internt → DMZ: Tillåts (administration).

- Internet → Internt: **Blockeras** (ska aldrig passera direkt).

### Trust Zones och VLAN

**Trust Zones:** Nätverkssegment grupperade efter förtroendenivå. Trafik mellan zoner kontrolleras av brandväggar/ACL:er. Exempel: extern zon (internet), DMZ, intern zon, restrikterad zon (ekonomi/HR), managementzon (nätverksadministration), serverzon.

**VLAN (Virtual LAN):** Logisk segmentering av fysiskt nätverk. Varje VLAN bildar egen broadcast-domän. Inter-VLAN-routing kräver brandvägg/L3-switch. Säkerhetsfördelar: begränsar broadcast, isolerar avdelningar, möjliggör granulär filtrering, kan kombineras med 802.1X.

### Micro-segmentering

Segmentering på applikations-/arbetsbelastningsnivå. Varje server, container eller applikation har egna regler. "Default deny" i alla riktningar, inklusive east-west-trafik. Centralt i Zero Trust-arkitekturer. Begränsar lateral movement dramatiskt.

## Säkerhetsprotokoll

### TLS/SSL

**Versioner:** SSL 2.0/3.0 – osäkra (POODLE-attack). TLS 1.0/1.1 – föråldrade. TLS 1.2 – brett använt, säkert. TLS 1.3 – senaste, snabbare handshake (1-RTT), borttagna osäkra chiffer.

**TLS Handshake (TLS 1.2, förenklat):**

1. **ClientHello:** Klient skickar stödda chiffer, TLS-version, slumpmässig nonce.
2. **ServerHello:** Server väljer chiffer, skickar sitt certifikat (utfärdat av CA) och nonce.
3. **Certifikatverifiering:** Klienten verifierar certifikatet mot trusted root CA:er.
4. **Nyckelutbyte:** Pre-master secret genereras, krypteras med serverns publika nyckel.
5. **Sessionsnycklar:** Båda parter beräknar symmetriska sessionsnycklar.
6. **Krypterad kommunikation:** All trafik krypteras med sessionsnycklarna.

**Cipher suite:** Kombination av algoritmer – nyckelutbyte (ECDHE), autentisering (RSA), symmetrisk kryptering (AES-256-GCM), hash (SHA-384). Exempel: `TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384`.

**Användning:** HTTPS (443), SMTPS, IMAPS, FTPS, LDAPS.

### IPsec

Kryptering, autentisering och integritet på nätverkslagret (Layer 3). Primär teknologi för VPN.

**Protokoll:**

- **AH (Authentication Header):** Autentisering + integritet, *ingen* kryptering. Skyddar hela IP-paketet.
- **ESP (Encapsulating Security Payload):** Autentisering + integritet + kryptering. Vanligast.

**Lägen:**

- **Transportläge:** Krypterar enbart payload. IP-header oförändrad. Host-to-host.
- **Tunnelläge:** Krypterar hela IP-paketet, ny header läggs till. Site-to-site och remote access VPN.

**IKE (Internet Key Exchange):** Förhandlar och etablerar IPsec-sessioner (Security Associations). Fas 1: säker kanal. Fas 2: IPsec-parametrar och sessionsnycklar.

### SSH (Secure Shell)

Krypterad fjärråtkomst, ersätter Telnet och rlogin. Standard port TCP 22.

**Autentisering:** Lösenord (svagast, sårbart för brute force), nyckelbaserad (nyckelpar, rekommenderad), certifikatbaserad (skalbart i stora miljöer).

**Funktioner:** Fjärrterminal, SCP/SFTP (filöverföring), SSH-tunnling/port forwarding (local, remote, dynamic/SOCKS), X11 forwarding.

**Härdning:** Ändra default-port, inaktivera root-login, inaktivera lösenordsautentisering, använda nyckelbaserad autentisering, begränsa tillåtna användare.

# Brandväggar

*Föreläsningar: 19 januari (teori) och 20 januari (praktik)*

En brandvägg kontrollerar nätverkstrafik mellan segment baserat på fördefinierade säkerhetsregler. Utgör en barriär mellan betrodda och icke betrodda nät.

## Packet Filter Firewall (Paketfilter)

**Funktion:** Inspekterar varje IP-paket individuellt baserat på header-information: käll/destinations-IP, käll/destinations-port, protokoll (TCP/UDP/ICMP), gränssnitt.

**Egenskaper: Stateless** – varje paket bedöms oberoende utan sessionskontext. Arbetar på OSI-lager 3–4. Implementeras ofta i routrar.

**Fördelar:** Mycket snabb, minimal overhead. Transparent för applikationer. Enkel, billig.

**Nackdelar:** Ingen innehållsinspektion. Ingen sessionsmedvetenhet – kan inte avgöra om svar tillhör legitim förfrågan. Sårbar för IP-spoofing och fragmenteringsattacker. Kan inte hantera applikationslagersattacker. Komplexa ACL:er svåra att underhålla.

## Stateful Firewall

**Funktion:** Håller en **state table** (session table) med alla aktiva anslutningar. Bedömer om paket tillhör befintliga, legitima sessioner.

**State table lagrar:** Käll/destinations-IP, käll/destinations-port, protokoll, sessionstillstånd (SYN_SENT, ESTABLISHED, FIN_WAIT), timeout.

**Exempel (TCP):**

1. Klient skickar SYN → brandvägg registrerar session, tillåter.
2. Server svarar SYN-ACK → matchar väntande session, tillåts.
3. Klient skickar ACK → session markeras ESTABLISHED.
4. Efterföljande trafik tillåts automatiskt.
5. Paket utan matchande session → nekas.

**Fördelar:** Mycket bättre säkerhet. Enklare regelhantering (behöver bara definiera en riktning). Kan hantera komplexa protokoll (FTP aktiv/passiv).

**Nackdelar:** Mer resurskrävande. **State table exhaustion:** SYN flood fyller tabellen → DoS. Inspekterar fortfarande inte applikationslagret.

## Application Layer Firewall (Proxy-brandvägg)

**Funktion:** Inspekterar trafik på Layer 7. Agerar som proxy – klient kommunicerar med brandväggen som öppnar separat anslutning till server.

**Typer:** Forward proxy (representerar klienten, intern → extern). Reverse proxy (representerar servern, extern → intern, döljer server, lastbalansering, caching).

**Fördelar:** Djup innehållsinspektion – kan blockera specifika HTTP-metoder, URL:er, SQL injection, XSS. Bryter direkt kontakt. Detaljerad loggning. Caching.

**Nackdelar:** Långsammare. Varje protokoll kräver specifik proxy. Kompatibilitetsproblem. Flaskhals vid hög trafik.

| | **Packet Filter** | **Stateful** | **Application Layer** |
|---|---|---|---|
| OSI-lager | 3–4 | 3–4 | 7 |
| Sessionsmedvetenhet | Nej | Ja | Ja |
| Innehållsinspektion | Nej | Nej | Ja |
| Prestanda | Hög | Medel | Lägre |
| Skyddsnivå | Grundläggande | God | Utmärkt |

## NGFW – Next-Generation Firewall

Kombinerar funktioner från alla tre typer plus avancerad funktionalitet:

- **Deep Packet Inspection (DPI):** Inspekterar hela paketinnehållet, inte bara headers. Identifierar skadlig kod och policyöverträdelser.
- **Applikationsidentifiering:** Identifierar applikationer oavsett port. Kan se att trafik på port 443 är YouTube vs Teams vs malware.
- **Integrerad IPS:** Blockerar kända exploits och attackmönster i realtid.
- **Användarmedvetenhet:** Kopplar trafik till specifika användare (AD/LDAP-integration). Policyer per användargrupp.
- **SSL/TLS-inspektion:** Dekrypterar, inspekterar, återkrypterar krypterad trafik. Nödvändigt eftersom allt mer trafik är krypterad. Agerar som MitM-proxy med egna certifikat.
- **Threat Intelligence:** Integration med molnbaserade hotdatabaser. Blockerar trafik till/från kända skadliga adresser.
- **Sandboxing:** Okända filer exekveras i isolerad miljö för beteendeanalys.

## UTM – Unified Threat Management

"Allt-i-ett"-lösning: brandvägg + antivirus + antispam + IDS/IPS + VPN + webbfiltrering + applikationskontroll + DLP.

**Fördelar:** Enkel hantering (en konsol), lägre kostnad. **Nackdelar:** Single point of failure, prestandaflaskhals.

NGFW: avancerad trafikinspektion, hög prestanda, medelstora–stora organisationer. UTM: bredare men ytligare funktionalitet, enkel hantering, små–medelstora organisationer. Gränserna suddas ut allt mer.

## Access Control Lists (ACL)

Ordnad lista av regler som avgör tillåten/nekad trafik. Varje regel: åtgärd (permit/deny), protokoll, käll-IP/port, destinations-IP/port.

**Bearbetning:** Uppifrån och ned. Första match avgör. Implicit `deny all` sist. Mest specifika regler först.

En bred `permit`-regel *före* en specifik `deny`-regel gör att deny-regeln aldrig nås. Alltid: specifika deny-regler *före* breda permit-regler.

**Best practices:** Principle of Least Privilege (börja med deny all, öppna selektivt). Dokumentera/namnge regler. Regelbunden revision. Logga deny-träffar.

## NAT och PAT

**NAT (Network Address Translation):** Översätter privata IP-adresser till publika.

- **Static NAT:** En-till-en. Permanent mappning. För servrar som behöver fast publik IP.
- **Dynamic NAT:** Pool av publika adresser tilldelas dynamiskt.
- **PAT (Port Address Translation):** Många-till-en. Alla delar en publik IP via unika portnummer. Vanligast.

**PAT-process:** Klient (192.168.1.10:50000) → NAT byter till publik IP + unik port (203.0.113.1:40001) → server svarar → NAT slår upp mappning → vidarebefordrar till klient.

**Säkerhetsaspekt:** NAT döljer intern struktur och blockerar oönskad inkommande trafik utan matchande tabellpost. **MEN:** NAT är *inte* en säkerhetsmekanism i sig – den designades för adressbesparing. Ersätter inte brandvägg.

## Brandväggspolicyer och regeldesign

**Designprocess:** Identifiera krav (vilka flöden behövs?) → Dokumentera (källa, destination, port, protokoll) → Skapa regler → Testa → Granska regelbundet.

**Gränssnitt:** WAN (internet, publik IP), LAN (internt, betrott), DMZ (exponerade tjänster). Varje gränssnitt tillhör en säkerhetszon med egen policy.

# Intrusion Detection & Prevention Systems

*Föreläsning: 26 januari 2026, 09:00–16:00*

## IDS – Intrusion Detection System

**Funktion:** Övervakar nätverkstrafik/systemaktivitet, analyserar mot kända mönster eller beteendeavvikelser, genererar larm. **Passivt** system – detekterar och larmar men blockerar *inte*.

**Placering:** Via port mirroring (SPAN) eller TAP. Sitter "vid sidan av" nätverket, inte inline.

**Typer:**

- **NIDS (Network-based):** Övervakar nätverkstrafik. Placeras vid nätverksgränser/segment.
- **HIDS (Host-based):** Installeras på enskilda värdar. Övervakar filer, loggar, processer, systemanrop. Exempel: OSSEC, Tripwire.

**Arbetsflöde:** Analys → detektion → larm till SIEM/analytiker → manuell granskning → bedömning (verkligt hot vs false positive) → vid verkligt hot: incidenthantering.

## IPS – Intrusion Prevention System

**Funktion:** Samma detektionskapacitet som IDS plus **automatisk blockering** av detekterade hot. **Aktivt** system.

**Placering: Inline** – all trafik passerar genom IPS:en.

**Åtgärder:** Drop (släpp paketet tyst), Reset (TCP RST), Block (blockera käll-IP under tid), Alert (bara larma), Quarantine (isolera enhet via NAC).

**Risker med inline:** Single point of failure (fail-open = ingen säkerhet; fail-close = avbrott). Latens. False positives blockerar legitim trafik.

**IDS vs IPS – fullständig jämförelse**

| | IDS | IPS |
|---|---|---|
| Funktion | Detektera och larma | Detektera och blockera |
| Agerande | Passivt | Aktivt |
| Placering | SPAN/TAP (vid sidan av) | Inline (trafiken igenom) |
| Prestandapåverkan | Minimal | Kan orsaka latens |
| Felscenario | Missad attack | Blockerad legitim trafik |
| Fail mode | Ingen direkt påverkan | Fail-open eller fail-close |
| Kräver analytiker? | Ja (granskar larm) | Nej (automatisk respons) |
| Bäst för | Övervakning, forensik | Realtidsskydd |

**IDS** = kameran (ser och larmar). **IPS** = vakten (ser och agerar).

## Detektionsmetoder

### Signaturbaserad detektion

Jämför trafik mot databas med kända attacksignaturer (unika mönster/"fingeravtryck").

**Signaturer:** Specifika byte-sekvenser, TCP-flaggkombinationer (SYN-scan), kända shellcode-mönster, HTTP-förfrågningar som matchar exploits.

**Styrkor:** Hög detektionsgrad kända hot. Låg false positive-rate. Snabb. Lätt att förstå larm.

**Svagheter:** Kan *inte* upptäcka zero-day. Polymorf malware ändrar signatur. Angripare kan modifiera attacker (evasion). Kräver konstanta uppdateringar.

### Beteendebaserad (anomali-baserad) detektion

Etablerar **baseline** av normalt beteende under inlärningsperiod, larmar vid avvikelser.

**Baseline-parametrar:** Normal bandbreddsanvändning, typiska trafikflöden, vanliga applikationer/protokoll, inloggningsmönster (tid, plats, frekvens), filöverföringsstorlek.

**Styrkor:** Kan upptäcka okända attacker och zero-day. Effektivt mot insiderhot. Fångar nya malware-varianter.

**Svagheter:** Hög false positive-rate. Inlärningsperioden sårbar (attack under inlärning = del av baseline). Baselinesläckage (gradvis ändring undviker larm). Svårtolkade larm.

Moderna IDS/IPS kombinerar **båda** metoderna. Signaturer fångar kända hot effektivt, beteendeanalys fångar det okända. Allt fler system använder maskininlärning (ML) för förbättrad anomali-detektion.

## False Positives och False Negatives

**Fyra utfall vid detektion**

| | **Verklig attack** | **Ingen attack** |
|---|---|---|
| **Larm** | True Positive (korrekt) | **False Positive** (falskt larm) |
| **Inget larm** | **False Negative** (missad attack) | True Negative (korrekt) |

**False Positive:** Larm utan verklig attack. Konsekvens: larmtrötthet, slöseri med resurser, IPS blockerar legitim trafik. Orsaker: för bred signatur, felkonfigurerad baseline, normal trafik som liknar attack.

**False Negative:** Missad verklig attack. Konsekvens: **allvarligast** – angriparen etablerar åtkomst utan detektion. Orsaker: saknad signatur (zero-day), krypterad trafik, evasion-tekniker.

**Avvägning:** Känsligare system = färre FN men fler FP. Mindre känsligt = färre FP men fler FN. Rätt balans beror på risktolerans.

## IDS/IPS-konfiguration och tuning

**Sensorplacering:** Bakom yttre brandvägg. Vid kritiska segmentgränser. Före känsliga resurser. HIDS på kritiska servrar (databaser, domänkontrollanter).

**Tuning (minska FP):** Inaktivera irrelevanta signaturer (t.ex. Linux-signaturer i Windows-miljö). Skapa undantag (whitelists). Justera tröskelvärden. Regelbunden granskning.

# Logganalys och SIEM

*Föreläsning: 27 januari 2026, 09:00–16:00*

## Loggkällor i ett nätverk

Varje enhet genererar loggar: brandväggar (tillåtna/nekade anslutningar, NAT, regelträffar), IDS/IPS (hot, blockeringar), servrar (inloggningar, systemhändelser, fel), nätverksutrustning (gränssnittsändringar, STP, konfigurationsändringar), operativsystem (Windows Event Logs, Linux syslog), applikationer (åtkomst, fel), proxyer (URL-förfrågningar, blockerade sidor), VPN-gateways (anslutningar, autentiseringar), DNS (frågor/svar), e-post (skickat/mottaget, spamfiltrering), endpoint protection (malware-detektioner).

## Centraliserad logghantering

**Varför centralisera?**

1. **Korrelation:** Se mönster som inte syns i enskilda loggar. Misslyckad inloggning på server A + lyckad inloggning från samma IP på server B = lateral movement.
2. **Tamperresistens:** Angripare rensar ofta lokala loggar. Centralt lagrade loggar bevaras.
3. **Sökbarhet:** Söka och filtrera över alla källor.
4. **Compliance:** GDPR, PCI DSS, SOX, ISO 27001 kräver loggning och lagring.
5. **Forensik:** Komplett bild vid incident kräver loggar från alla berörda system.

**Loggöverföring:** Syslog (RFC 5424, UDP 514 osäkert / TCP 6514 med TLS), agentbaserad (Splunk UF, Elastic Agent, Wazuh), API-baserad (molntjänster).

**Lagring:** Retentionspolicyer (90 dagar–1 år), varm-/kalllagring, WORM-skydd (Write Once Read Many).

## SIEM – Security Information and Event Management

**SIEM – kärnfunktioner**

1. **Logginsamling:** Samlar loggar från hela infrastrukturen i realtid. Stöder multipla format/protokoll. Hanterar tusentals EPS (Events Per Second).
2. **Normalisering:** Konverterar till enhetligt schema. Standardiserar fältnamn ("source_ip" oavsett källformat).
3. **Korrelation:** Analyserar händelser från flera källor. Korrelationsregler triggar larm. Identifierar komplexa attackkedjor. Tidskorrelation: "Om A följs av B inom X minuter, larma."
4. **Larmgenerering:** Larm vid regelträff. Prioritering (critical/high/medium/low). Notifiering via e-post, SMS, ticketsystem.
5. **Dashboards och rapportering:** Realtids-säkerhetsöversikt, trendanalys, compliance-rapporter.
6. **Forensik:** Sökfunktionalitet, tidslinje-rekonstruktion, pivoting (utgå från en händelse, utforska relaterade).

**Brute force:** 100+ misslyckade inloggningsförsök från samma IP inom 5 min → larm HÖG.
**Lateral movement:** Användarkonto loggar in på 5+ servrar inom 10 min (normalt 1–2) → larm.
**Dataexfiltrering:** Utgående trafik från intern server >500 MB under icke-kontorstid till icke-whitelistad extern IP → larm.
**Credential stuffing:** Misslyckade inloggningar mot *olika* konton från samma IP → larm.

## Indikatorer på säkerhetsincidenter (IoC)

- Upprepade misslyckade inloggningar (brute force, credential stuffing, password spraying).
- Lyckad inloggning efter många misslyckade (angriparen lyckades).
- Inloggning vid ovanliga tidpunkter eller från ovanliga geolokationer ("impossible travel").
- Plötslig ökning av utgående trafik (dataexfiltrering).
- Kommunikation med kända skadliga IP/domäner (C2-trafik).
- Ändringar i systemfiler eller konfigurationer (rootkits, bakdörrar).
- Nya/oväntade tjänster eller processer (malware-installation).
- Behörighetseskalering (vanligt konto får admin-rättigheter).
- Stora/ovanliga DNS-frågor (DNS tunneling).
- Systematisk portscanning.
- Lateral movement (inloggning på system utanför normal profil).

**SIEM-plattformar:** Splunk (marknadsledande, SPL-frågespråk), IBM QRadar (stark korrelation), Microsoft Sentinel (molnbaserat, Azure-integration, SOAR), Elastic Security (open source, ELK), Wazuh (open source, HIDS + SIEM).

# SASE – Secure Access Service Edge

*Föreläsning: 2 februari 2026, 09:00–16:00*

## Varför behövs SASE?

Traditionella modellen ("castle-and-moat"): allt i centralt datacenter, alla på kontoret, brandvägg vid gränsen, VPN för fjärranvändare.

**Vad som förändrats:** Molnmigration (SaaS, IaaS, PaaS). Distansarbete. BYOD. IoT. Backhauling via DC skapar latens/flaskhalsar. Perimetern har upplösts – säkerheten måste följa användaren.

## SASE – definition

SASE (uttalas "sassy", myntades av Gartner 2019) konvergerar nätverks- och säkerhetsfunktioner i en molnlevererad tjänst. Istället för att routa all trafik till DC levereras säkerhet från molnet, nära användaren.

**De fem SASE-komponenterna**

**1. SD-WAN (Software-Defined WAN)**
- Separerar kontrollplan från dataplan. Central, mjukvarudefinierad trafikstyrning.
- Intelligent routing baserat på applikationskrav (realtid prioriteras på bästa länk).
- Transportoberoende: MPLS, bredband, 4G/5G, satellit.
- Centraliserad hantering ("single pane of glass"), ingen manuell routerkonfiguration per kontor.
- Kontinuerlig kvalitetsövervakning (latens, jitter, paketförlust), automatisk failover.
- Direct Internet Access: filialer når molntjänster direkt utan backhauling.

**2. FWaaS (Firewall as a Service)**
- NGFW-funktionalitet från molnet: DPI, applikationskontroll, IPS, URL-filtrering.
- Automatisk skalning, ingen hårdvara att uppgradera.
- Konsistent policy oavsett användarens plats.
- All trafik inspekteras vid närmaste PoP (Point of Presence).
- Eliminerar fysiska brandväggar per kontor.

**3. SWG (Secure Web Gateway)**
- Säker proxy för all webbtrafik.
- URL-filtrering (kategoribaserad blockering).
- Malware-skanning av nedladdningar och webbinnehåll i realtid.
- SSL/TLS-inspektion av krypterad webbtrafik.
- DLP – förhindrar uppladdning av känslig data till obehöriga sidor.
- Bandbreddskontroll för icke-affärskritiska webbplatser.

**4. CASB (Cloud Access Security Broker)**
- Kontrollpunkt mellan användare och molntjänster.
- **Synlighet:** Vilka molntjänster används? Identifiera Shadow IT.
- **Compliance:** Kontrollera att molnanvändning följer policyer/regelverk.
- **Dataskydd:** Kryptering, tokenisering, DLP i molntjänster. Blockera delning av känsliga dokument.
- **Hotskydd:** Detektera anomalt beteende i molntjänster (masskopiering, malware).
- **Åtkomstkontroll:** Granulär – t.ex. "tillåt företagets SharePoint men blockera personliga OneDrive".
- **Deployment:** Forward proxy (agentkrävande), reverse proxy (agentfritt), API-baserad (out-of-band).

**5. ZTNA (Zero Trust Network Access)**
- Identitetsbaserad åtkomst, ersätter traditionell VPN.
- Åtkomst till *specifika applikationer*, inte hela nätverket.
- Verifierar användare OCH enhet vid varje åtkomstförsök.
- Osynlig infrastruktur – applikationer exponeras inte utan giltig autentisering.
- Kontinuerlig utvärdering – åtkomst kan återkallas vid ändrad enhetsstatus.

**Cloud-delivered security:** All funktionalitet från globalt distribuerade PoP:er. Inspektion vid närmaste PoP. Konsistenta policyer globalt. Automatiska uppdateringar.

SASE = **Nätverk** (SD-WAN) + **Säkerhet** (FWaaS + SWG + CASB + ZTNA), levererat från **molnet**. Arkitekturmodell, inte en enskild produkt.

### Traditionell säkerhet vs SASE

| **Aspekt** | **Traditionellt** | **SASE** |
|---|---|---|
| Perimeter | Fysisk brandvägg vid kontor | Följer användaren |
| Arkitektur | Hub-and-spoke (allt genom DC) | Distribuerad, molnbaserad |
| Skalbarhet | Begränsad av hårdvara (CAPEX) | Elastisk (OPEX) |
| Fjärranvändare | VPN till kontoret (latens) | Direkt åtkomst via ZTNA |
| Molntrafik | Backhaul via DC (flaskhals) | Direkt via närmaste PoP |
| Hantering | Separata konsoler per produkt | En unified molnkonsol |
| Uppdateringar | Manuell firmware | Automatiska i molnet |
| Policykonsistens | Svårt (olika enheter/platser) | Samma policy globalt |

# Zero Trust

*Föreläsning: 3 februari + repetition 10 februari 2026*

## Paradigmskiftet

Traditionellt: implicit tillit innanför perimetern. Zero Trust: **inget och ingen litas på, oavsett position**. Varje åtkomstförsök verifieras explicit, varje gång.

**Varför:** Insiderhot utnyttjar implicit tillit. Lateral movement i platta nätverk. Molnet och distansarbete upplöste perimetern. VPN ger för bred åtkomst.

## Tre grundprinciper

**Zero Trust – principerna**

**1. Verifiera explicit (Verify Explicitly)**
Autentisera och auktorisera baserat på *alla tillgängliga datapunkter*: identitet (stark autentisering, MFA), enhet (MDM-status, patchnivå, antivirus, diskkryptering), plats (IP-geolokation, nätverkstyp), tjänst/resurs som efterfrågas, dataklassificering, beteendeavvikelser (riskpoäng).

**2. Minsta möjliga behörighet (Least Privilege Access)**

- **JIT (Just-in-Time):** Behörighet tillfälligt, återkallas automatiskt.
- **JEA (Just-Enough-Access):** Bara behörighet för specifik uppgift.
- **RBAC:** Behörigheter kopplas till roller.
- Regelbundna åtkomstgranskningar. Segmentering.

**3. Anta intrång (Assume Breach)**

- Micro-segmentering minimerar "blast radius".
- End-to-end-kryptering även internt.
- Kontinuerlig övervakning (SIEM, EDR, NDR).
- Automatiserad respons vid detektion.
- Red team/Blue team-övningar.

## ZTNA vs VPN

| | VPN | ZTNA |
|---|---|---|
| Åtkomstnivå | Hela nätverket | Specifika applikationer |
| Autentisering | Vid anslutning (en gång) | Kontinuerlig |
| Enhetsvalidering | Begränsad/ingen | Obligatorisk |
| Lateral movement | Möjlig | Begränsad |
| Skalbarhet | VPN-koncentrator flaskhals | Molnbaserad, elastisk |
| Attackyta | Exponerad VPN-gateway | Appar osynliga utifrån |

## IAM – Identity and Access Management

### Autentisering

- **Single Factor:** Bara lösenord. Svagast.
- **MFA:** Minst två av: *något du vet* (lösenord, PIN), *något du har* (YubiKey, authenticator-app, smartkort), *något du är* (fingeravtryck, ansiktsigeknänning).

- **Passwordless:** FIDO2/WebAuthn med hårdvarunyckel + biometri. Eliminerar phishing av lösenord.

### SSO (Single Sign-On)

En inloggning ger åtkomst till alla auktoriserade tjänster. Protokoll: SAML 2.0 (XML, enterprise), OAuth 2.0 + OIDC (JSON, web/API), Kerberos (Active Directory).

**Fördel:** Färre lösenord = färre svaga/återanvända. Bättre UX. Centraliserad styrning. **Risk:** Kompromettterat SSO-konto ger åtkomst till allt – MFA ännu viktigare.

### RBAC

Behörigheter tilldelas roller ("Nätverksadmin", "Supporttekniker"), användare tilldelas roller. Förenklar hantering. ABAC (Attribute-Based) ger finare granularitet.

### Identity Providers (IdP)

Active Directory (on-prem, LDAP + Kerberos), Azure AD/Entra ID (molnbaserat, Microsoft 365), Okta (SSO + MFA-specialist), LDAP (öppen standard).

# Penetrationstestning och sårbarhetsscanning

*Föreläsning: 9 februari (repetition 16 februari)*

## Etisk hacking

Penetrationstestning är en auktoriserad, kontrollerad simulering av en cyberattack i syfte att identifiera sårbarheter innan riktiga angripare utnyttjar dem.

**Alltid** skriftligt tillstånd. Utan tillstånd = dataintrång (BrB 4 kap. 9c §). Innan testet definieras: **Scope** (vilka system får testas), **Rules of Engagement** (tillåtna metoder, tidsramar, kontaktpersoner, begränsningar), **Nödförfarande** (om system kraschar). All aktivitet dokumenteras. Fynd rapporteras enbart till beställaren.

## Typer av penetrationstest

| | **Black Box** | **Gray Box** | **White Box** |
|---|---|---|---|
| Information | Ingen | Begränsad (diagram, IP, viss inlogg) | Full (källkod, arkitektur, inlogg) |
| Simulerar | Extern angripare | Insider/kompromettterat konto | Grundlig granskning |
| Tid | Mest (allt från noll) | Medel | Mest effektiv per timme |
| Realism | Mest realistisk | Medel | Minst realistisk |

## Faserna i ett penetrationstest

**Fem faser – detaljerat**

**Fas 1: Reconnaissance (Spaning)**
*Passiv* (ingen kontakt med målet): OSINT, DNS-uppslag (`nslookup`, `dig`), WHOIS, Google dorking (`site:`, `filetype:`, `intitle:`), sociala medier (LinkedIn), Shodan/Censys (sökmotorer för internetenheter), Certificate Transparency-loggar (hitta subdomäner), Wayback Machine (historiska sidor).
*Aktiv* (direkt kontakt, detekterbar): Portscanning (Nmap), tjänsteenumeration, OS fingerprinting, banner grabbing, nätverksmappning.
**Fas 2: Scanning**
Portscanning (Nmap): TCP SYN scan (-sS, halvöppen, vanligast), TCP Connect (-sT, fullständig handshake, synlig i loggar), UDP scan (-sU, långsammare), stealth scans (FIN, NULL, Xmas). Tjänsteidentifiering (-sV). OS-detektion (-O). NSE-skript (tusentals skript för avancerade tester). Sårbarhetsscanning (Nessus/OpenVAS mot CVE-databaser).
**Fas 3: Exploitation (Utnyttjande)**
Utnyttja identifierade sårbarheter: remote code execution, lösenordsattacker (brute force, dictionary, credential stuffing), SQL injection, buffer overflow, social engineering. Minimera skada. Dokumentera varje steg med bevis.
**Fas 4: Post-Exploitation**
Privilege escalation (vanlig användare → admin/root). Lateral movement (röra sig i nätverket). Persistence (bakdörrar – demonstrera risken). Data exfiltration (bevisa att känslig data kan hämtas). Pivoting (kompromettterat system som språngbräda till andra segment).
**Fas 5: Rapportering**
Executive summary (för ledningen, affärsrisk). Teknisk rapport per sårbarhet: beskrivning, CVSS-allvarlighetsgrad, steg att reproducera, bevis (screenshots/loggar), rekommenderade åtgärder, prioritering. Strategiska förbättringsförslag.

## Verktyg

### Nmap (Network Mapper)

- **Syfte:** Nätverksutforskning, portscanning, tjänste-/OS-identifiering.
- **Fas:** Reconnaissance och Scanning.
- **Kärnfunktioner:** Portscanning (TCP/UDP), Version Detection (-sV), OS Detection (-O), NSE, traceroute, host discovery (-sn).
- **Output:** XML, HTML, grep-format.
- **Besvarar:** "Vad finns i nätverket?" (portar, tjänster, operativsystem).

### Nessus

- **Syfte:** Kommersiell sårbarhetsskanner.
- Skannar mot stor CVE-databas (Common Vulnerabilities and Exposures).
- Genererar rapporter med **CVSS-poäng** (Common Vulnerability Scoring System, 0–10) och åtgärdsrekommendationer.
- Kan skanna nätverksenheter, servrar, applikationer, databaser.
- **Besvarar:** "Vad är sårbart?" (kända brister, patchstatus).

### OpenVAS

- Open source-alternativ till Nessus. Liknande funktionalitet.
- Gratis men mer komplext att konfigurera.
- Samma typ av CVE-baserad skanning.

**Nmap:** kartlägger vad som *finns* (portar, tjänster, OS). **Nessus/OpenVAS:** identifierar vad som är *sårbart* (CVE:er, patchstatus). I ett pentest: Nmap först (kartlägga), sedan sårbarhetsskanner (identifiera brister).

### Sårbarhetsbedömning vs penetrationstest

| | **Sårbarhetsbedömning** | **Penetrationstest** |
|---|---|---|
| Mål | Identifiera och lista sårbarheter | Bevisa att sårbarheter kan utnyttjas |
| Metod | Automatiserad skanning | Manuell + automatiserad |
| Djup | Bred, ytligare | Smalare, djupare |
| Exploitation | Nej | Ja |
| Frekvens | Regelbundet (veckovis/månatligt) | Periodiskt (årligen/halvårsvis) |

# Nätverksattacker och försvar

*Föreläsning: 17 februari 2026 (förhandsmaterial – fullständig föreläsning kommande)*

Kursmål: redogöra för hur olika nätverksattacker går till, hur man kan upptäcka dem och hur man kan hantera dem.

## DDoS – Distributed Denial of Service

**Syfte:** Göra en tjänst otillgänglig genom att överbelasta den med trafik. **CIA:** Attackerar **Availability**.
**Metod:** Distribuerad trafik från många källor, ofta via botnet (tusentals kompromettterade enheter).
**Typer:**

- **Volumetrisk:** Översvämma bandbredd (UDP flood, DNS amplification, NTP amplification). Mäts i Gbps.
- **Protokollattack:** Utnyttja protokollsvagheter. SYN flood (fyller state table med halvöppna anslutningar), Smurf attack (ICMP broadcast). Mäts i packets/sec.
- **Applikationslagersattack:** Rikta sig mot specifika applikationer. HTTP flood (överbelasta webbserver med GET/POST-förfrågningar), Slowloris (hålla många anslutningar halvöppna). Svårast att detektera – ser ut som normal trafik.

**Detektion:** Plötslig trafikökning, ovanligt hög CPU/minnesanvändning, ökad latens, misslyckade anslutningar, SIEM-korrelation.
**Försvar:** DDoS-mitigeringstjänster (Cloudflare, AWS Shield, Akamai), rate limiting, trafikfiltrering, CDN (distribuerar last), geo-blocking, överkapacitet/redundans, SYN cookies (mot SYN flood), BCP38 (ingress filtering mot IP-spoofing).

## Man-in-the-Middle (MitM)

**Syfte:** Avlyssna, ändra eller injicera trafik mellan två kommunicerande parter. **CIA:** Attackerar **Confidentiality** och **Integrity**.
**Metod:** Angriparen placerar sig mellan avsändare och mottagare. Båda parter tror de kommunicerar direkt med varandra. Vanligt i osäkra Wi-Fi-nätverk.
**Varianter:** ARP poisoning (LAN-baserad MitM), DNS spoofing (omdirigering), SSL stripping (nedgradera HTTPS till HTTP), Evil twin (falsk Wi-Fi-accesspunkt), DHCP spoofing (falsk DHCP-server).
**Vad angriparen kan göra:** Läsa känslig data (lösenord, kreditkort), modifiera data under transit, injicera skadlig kod, kapa sessioner.
**Detektion:** Certifikatvarningar i webbläsare, ovanlig nätverkslatens, ARP-tabellförändringar, duplicerade MAC-adresser.
**Försvar:** Kryptering (TLS/SSL), certifikatvalidering, VPN, HSTS (HTTP Strict Transport Security – tvingar HTTPS), certifikat-pinning, nätverksövervakning.

## ARP Poisoning (ARP Spoofing)

**Syfte:** Manipulera ARP-tabeller på lokalt nätverk för att omdirigera trafik. **CIA: Confidentiality** och **Integrity**.
**Bakgrund – ARP:** Address Resolution Protocol mappar IP-adresser till MAC-adresser på lokala nätverk. ARP har inget inbyggt autentiseringsmekanismer – alla enheter litar på mottagna ARP-svar.
**Metod:** Angriparen skickar falska (gratuitous) ARP-svar till mål-enheterna. "Jag är 192.168.1.1 (routern) och min MAC-adress är [angriparens MAC]." Alla enheter som mottar meddelandet uppdaterar sina ARP-tabeller. Trafik som ska till routern går istället till angriparen. Angriparen vidarebefordrar trafiken till den riktiga routern (för att undvika detektion) – klassisk MitM.
**Konsekvenser:** Avlyssning av all LAN-trafik, sessionskapning, injektion av skadlig data.
**Detektion:** Duplicerade IP-till-MAC-mappningar, ARP-tabellförändringar, verktyg som ARPwatch.
**Försvar:** Statiska ARP-poster (opraktiskt i stora nätverk), **Dynamic ARP Inspection (DAI)** (switch verifierar ARP-paket mot DHCP snooping-databas), nätverkssegmentering, 802.1X, krypterade protokoll (MitM kan avlyssna men inte dekryptera).

## DNS Spoofing (DNS Cache Poisoning)

**Syfte:** Omdirigera användare till skadliga webbplatser genom att manipulera DNS-svar. **CIA: Integrity** och **Confidentiality**.
**Bakgrund – DNS:** Översätter domännamn (t.ex. bank.se) till IP-adresser. DNS-resolver cachelagrar svar för prestanda.
**Metod:** Angriparen manipulerar DNS-svar så att ett domännamn pekar till fel IP-adress (angriparens server). Kan ske genom: kompromittera DNS-server, poisona DNS-resolvers cache (injicera falskt svar innan det riktiga anländer), MitM mot DNS-trafik (DNS använder oftast UDP som är lättare att förfalska).
**Konsekvenser:** Användare tror de besöker bank.se men är på en identisk kopia som kontrolleras av angriparen (phishing i stor skala). Stöld av inloggningsuppgifter, malware-distribution.
**Detektion:** DNSSEC-validering, övervakning av DNS-poster, analys av DNS-svars TTL och mönster.
**Försvar: DNSSEC** (signerar DNS-svar kryptografiskt), **DNS over HTTPS (DoH)** och **DNS over TLS (DoT)** (krypterar DNS-frågor), randomisering av port och transaktions-ID, DNS-resolvers med query validation.

## Social Engineering och Phishing

**Syfte:** Utnyttja den mänskliga faktorn för att få åtkomst till system eller information. **CIA:** Kan attackera **alla tre** beroende på vad angriparen uppnår.
**Social Engineering:** Manipulation av personer för att utföra handlingar eller avslöja information. Utnyttjar psykologiska principer: auktoritet, brådska, rädsla, hjälpsamhet, nyfikenhet.
**Phishing-varianter:**

- **Phishing:** Mass-utskick av falska e-postmeddelanden som lurar mottagare att klicka på skadliga länkar eller bifogade filer, eller lämna ifrån sig inloggningsuppgifter.
- **Spear phishing:** Riktat mot specifika individer/organisationer med personanpassat innehåll.
- **Whaling:** Riktat mot högt uppsatta chefer.
- **Vishing:** Via telefon ("voice phishing").
- **Smishing:** Via SMS.
- **Business Email Compromise (BEC):** Angriparen utger sig för att vara VD/ekonomichef och beordrar en betalning.

**Detektion:** Ovanliga e-postmönster, SIEM-korrelation med inloggningsdata, rapporterade misstänkta e-postmeddelanden, DMARC/DKIM/SPF-rapporter.
**Försvar:** Utbildning och medvetandehöjning (regelbundna simuleringar), e-postfiltrering (anti-phishing gateways), **MFA** (stöld av lösenord räcker inte), Zero Trust (begränsad åtkomst även vid kompromettterat konto), **DMARC/SPF/DKIM** (e-postautentisering – förhindrar domänförfalskning), rapporteringskultur (uppmuntra anställda att rapportera misstänkta e-postmeddelanden).

# Ordlista: engelska termer

Att kunna de engelska termerna är ett explicit kursmål. Alla viktiga termer samlade nedan.

| Term | Betydelse |
|---|---|
| **Grundläggande säkerhet** | |
| Confidentiality | Konfidentialitet – information nås bara av behöriga |
| Integrity | Integritet – information ändras inte obehörigt |
| Availability | Tillgänglighet – system och data kan nås |
| Threat | Hot |
| Vulnerability | Sårbarhet |
| Risk | Sannolikhet × konsekvens |
| Asset | Tillgång |
| Exploit | Metod/kod som utnyttjar en sårbarhet |
| Attack Surface | Attackyta – alla potentiella ingångspunkter |
| Threat Actor | Hotaktör |
| Defense in Depth | Djupförsvar – flera säkerhetslager |
| DMZ | Demilitarized Zone – zon mellan externt/internt nät |
| Trust Zone | Nätverkszon med definierad förtroendenivå |
| Micro-segmentation | Segmentering per applikation/arbetsbelastning |
| **Protokoll** | |
| TLS/SSL | Transport Layer Security (krypterar transportlagret) |
| IPsec | Internet Protocol Security (krypterar nätverkslagret) |
| SSH | Secure Shell (krypterad fjärråtkomst) |
| AH | Authentication Header (IPsec – integritet) |
| ESP | Encapsulating Security Payload (IPsec – kryptering + integritet) |
| IKE | Internet Key Exchange (IPsec-sessionsförhandling) |
| Cipher Suite | Kombination av krypteringsalgoritmer i TLS |
| **Brandväggar** | |
| Packet Filter | Enklaste brandväggen, stateless, Layer 3–4 |
| Stateful Firewall | Tillståndsbaserad brandvägg, state table |
| Application Layer Firewall | Proxy-brandvägg, Layer 7 |
| NGFW | Next-Generation Firewall |
| UTM | Unified Threat Management |
| DPI | Deep Packet Inspection |
| ACL | Access Control List – regeluppsättning |
| NAT / PAT | Adressöversättning / Portbaserad adressöversättning |
| Implicit Deny | Osynlig “neka allt”-regel sist i ACL |
| Least Privilege | Minsta möjliga behörighet |
| **Detektering & övervakning** | |
| IDS | Intrusion Detection System (passivt, larmar) |
| IPS | Intrusion Prevention System (aktivt, blockerar) |
| NIDS / HIDS | Network-based / Host-based IDS |
| Signature-based detection | Signaturbaserad – matchar mot kända mönster |
| Anomaly-based detection | Beteendebaserad – larmar vid avvikelser från baseline |
| False Positive | Falskt larm – attack rapporteras men finns inte |
| False Negative | Missad attack – verklig attack detekteras inte |
| True Positive / True Negative | Korrekt detektion / korrekt tystnad |
| SIEM | Security Information and Event Management |
| EPS | Events Per Second (SIEM-kapacitet) |
| IoC | Indicator of Compromise |
| Correlation Rule | SIEM-regel som triggar larm vid mönstermatchning |

# Studietips och tentamensförberedelse

## Tentamen

**Datum:** 20 februari 2026, kl. 09:00–12:00. **Form:** Skriftligt prov. **Rättigheter:** En ordinarie examination och två omexaminationer.

**Betyg:** IG (ej nått alla kursmål), G (nått alla kursmål), VG (nått alla kursmål med säkerhet och skicklighet – kunna välja/motivera verktyg och metoder, installera/konfigurera brandväggar, genomföra nätverkstester, diagnostisera problem, genomföra riskanalyser).

## Studiestrategier

1. **Förstå koncepten – lär inte utantill.** Om du förstår *varför* vi använder en stateful brandvägg istället för packet filter kan du resonera dig fram, även vid oväntade frågor.
2. **Öva på att jämföra och kontrastera:**
   - Packet filter vs stateful vs application layer
   - NGFW vs UTM
   - IDS vs IPS
   - Signaturbaserad vs beteendebaserad detektion
   - Traditionell säkerhet vs SASE
   - VPN vs ZTNA
   - Black box vs gray box vs white box pentest
   - Nmap vs Nessus/OpenVAS
   - Sårbarhetsbedömning vs penetrationstest
3. **Tänk praktiskt och motivera teknikval.** "Om du fick i uppgift att säkra ett företagsnätverk – vilka lösningar väljer du och varför?" Kunna motivera val utifrån scenario och krav.
4. **Lär dig de engelska termerna.** Explicit kursmål. Använd ordlistan. Var beredd på att förklara termer med egna ord.
5. **Koppla ihop allt.** Defense in Depth innebär att kombinera brandväggar, IDS/IPS, SASE och Zero Trust. Penetrationstestning verifierar att allt fungerar. SIEM ger övervakning. Allt bygger på riskanalys och CIA-triaden.

## Kontrollfrågor att öva på

**Grundläggande säkerhet (Kap. 1):**

1. Förklara CIA-triaden och ge ett konkret exempel på skyddsåtgärd och hot för varje del.
2. Beskriv riskanalysprocessen i fem steg.
3. Vad är skillnaden mellan ett hot, en sårbarhet och en risk?
4. Vilka fyra strategier finns för riskhantering? Ge ett exempel på varje.
5. Vad menas med attackyta (attack surface)?

**Nätverksarkitektur (Kap. 2):**

6. Vad innebär Defense in Depth? Beskriv minst fem lager.
7. Förklara vad en DMZ är, hur den är uppbyggd och vilka tjänster som typiskt placeras där.
8. Vad är skillnaden mellan single-firewall och dual-firewall DMZ?
9. Beskriv TLS-handshaken i fem steg.
10. Vad skiljer IPsec transportläge från tunnelläge? Vad är AH vs ESP?
11. Vad är SSH och vilka autentiseringsmetoder stöds?

**Brandväggar (Kap. 3):**

12. Beskriv skillnaden mellan packet filter, stateful och application layer-brandväggar.
13. Vad är en state table och hur fungerar den?
14. Vad är en ACL? Varför är regelordningen avgörande? Vad är implicit deny?
15. Vad gör en NGFW som en traditionell brandvägg inte kan? Nämn minst fem funktioner.
16. Vad är skillnaden mellan NGFW och UTM?
17. Förklara NAT, Static NAT, Dynamic NAT och PAT. Är NAT en säkerhetsmekanism?
18. Vad är state table exhaustion och hur kan det användas som attack?

**IDS/IPS (Kap. 4):**

19. Jämför IDS och IPS – funktion, placering, fördelar, nackdelar.
20. Beskriv signaturbaserad vs beteendebaserad detektion med styrkor och svagheter.
21. Definiera false positive och false negative. Vilken är farligast och varför?
22. Vad är skillnaden mellan NIDS och HIDS?
23. Vad menas med fail-open respektive fail-close i en IPS?

**Logganalys/SIEM (Kap. 5):**

24. Varför centralisera loggar? Nämn minst fyra skäl.
25. Vad gör ett SIEM-system? Beskriv kärnfunktionerna.
26. Ge tre exempel på korrelationsregler.
27. Nämn fem indikatorer på säkerhetsincidenter (IoC) i loggar.

**SASE (Kap. 6):**

28. Varför fungerar den traditionella säkerhetsmodellen inte längre?
29. Vilka fem komponenter ingår i SASE? Förklara varje kort.
30. Vad är Cloud-delivered security?
31. Jämför traditionell säkerhet med SASE i minst fem aspekter.
32. Vad är Shadow IT och hur adresserar CASB det?

**Zero Trust (Kap. 7):**

33. Nämn de tre grundprinciperna i Zero Trust och förklara varje.
34. Vad är ZTNA och hur skiljer det sig från VPN? Nämn minst fyra skillnader.
35. Förklara MFA och dess tre kategorier.
36. Vad är SSO, vilka protokoll finns och vilka risker medför det?
37. Vad är RBAC?

**Pentesting (Kap. 8):**

38. Beskriv de fem faserna i ett penetrationstest.
39. Vad skiljer black box, gray box och white box-test?
40. Ge minst fyra exempel på passiv reconnaissance.
41. Vad är skillnaden mellan Nmap och Nessus? När används respektive?
42. Vad är CVSS?
43. Varför kräver penetrationstestning skriftligt tillstånd?

**Nätverksattacker (Kap. 9):**

44. Förklara hur en DDoS-attack fungerar, nämn tre typer och tre försvarsåtgärder.
45. Beskriv en MitM-attack och hur man skyddar sig.
46. Förklara ARP poisoning steg för steg. Hur kan det motverkas?
47. Vad är DNS spoofing och vilka skyddsmekanismer finns?
48. Beskriv minst fyra typer av phishing.
49. Vilken del av CIA-triaden attackerar varje attacktyp?

50. Ge ett scenario där du kombinerar flera koncept: en organisation utsätts för en attack – beskriv hur du skulle använda brandväggar, IDS/IPS, SIEM och incidenthantering för att detektera och hantera den.

## Lycka till på tentan den 20 februari!

*Glöm inte: föreläsningen den 17 februari om nätverksattacker och försvar är den sista före tentan. Se till att komma!*